

Project Blueprint: "Cyber-62443-Assure" SaaS Platform

Part I: The BMAD Constitution (Project "Cyber-62443-Assure")

File: /memory/constitution.md

This document serves as the foundational, non-negotiable set of principles for all human stakeholders and AI agents involved in the development of the "Cyber-62443-Assure" platform. It ensures all generated artifacts adhere to the project's core directives, acting as a single source of truth for maintaining context and consistency.¹

A. Foundational Principles (Adapted from BMAD)

- **Principle 1: Single Source of Truth (SSOT)**
All planning, architecture, PRD, and implementation artifacts shall be versioned and centralized in the project's Git repository. The "spec is the truth." All development, whether human- or AI-driven, must originate from a versioned specification. "Vibe coding," or unstructured prompting without a corresponding artifact, is explicitly forbidden.¹
- **Principle 2: Traceability and Accountability**
Every change to the specification or codebase, whether from a human or an AI agent, must be thoroughly tracked through Git commits and associated with a user story or task. All AI-generated content must be auditable.¹
- **Principle 3: Human-in-the-Loop (HITL) Gating**
Every AI-generated artifact (e.g., code, documentation, UI component) must undergo a rigorous pull request (PR) review by a designated human expert (e.g., Senior Developer, Architect, Security Lead) before being merged. This is a non-negotiable human checkpoint to prevent "runaway" automation and validate quality.²

- Principle 4: Adherence to Specification
All AI agents must strictly adhere to the PRD (Part II) and System Architecture (Part III) documents. Any ambiguity or conflict discovered in the specifications must be flagged for human review and refinement, not resolved with assumptions.

B. Core Directives (Project-Specific Guardrails)

- Directive 1: Workflow Integrity
The application's primary function is to facilitate the IEC 62443 standard. All workflows, UI elements, and data models must directly map to the processes defined in the IEC 62443 series. The standard itself is the workflow (e.g., 62443-3-2 for Risk Assessment, 62443-4-1 for Secure Development Lifecycle).⁴ The application must guide users through the standard's lifecycle, not replace its logic.
- Directive 2: Facilitator-Centric Control
The "Facilitator" (Consultant) persona is the ultimate authority for all client project workflow progression. The system must be designed with explicit "state-gating" UI. Client personas (Asset Owner, Product Supplier) can "submit" work, but only the Facilitator persona can "approve" and advance the project to the next phase. This implements the HITL principle at the application's business logic level.⁷
- Directive 3: Evidence-Based Compliance
All compliance assertions (e.g., "SL-A 3 is met for SR 1.1") are meaningless without auditable proof. The system must be architected around a centralized "Evidence Locker." Every compliance checkbox, requirement, and control must be programmatically linked to a specific, versioned piece of evidence.⁹
- Directive 4: AI as Facilitator, Not Decider
The platform's AI (leveraging the GraphRAG architecture) is a co-pilot, not an automated decision-maker. Its role is to facilitate (e.g., "Here are 5 threats from MITRE ATT&CK for ICS that target PLCs"), summarize (e.g., "This zone's SL-A is 1, but its SL-T is 2. The gap is in SR 1.1"), and recommend (e.g., "You should add these 3 CSET-style questions"). It shall never make a final risk-acceptance or compliance-approval decision.
- Directive 5: Pragmatic Reusability
To accelerate development, as requested, development will "keep it simple" by prioritizing pre-made, well-maintained components and tools. This includes shadcn/ui and Tailwind CSS for the UI ¹², React Flow for the canvas ¹³, and managed services (e.g., Supabase Realtime) for complex features like real-time collaboration.¹⁴ Open-source solutions should be favored where practical.

Part II: Product Requirements Document (PRD) -

"Cyber-62443-Assure" SaaS Platform

This document, based on the BMAD template structure ¹, defines the "what" of the platform.

1. Vision and Strategic Fit

1.1. Problem Statement

The IEC 62443 standard is the global benchmark for Operational Technology (OT) and Industrial Automation and Control Systems (IACS) cybersecurity.⁶ Despite its importance, adoption is slow and fraught with challenges.¹⁶ Organizations struggle with:

- **Complexity:** The standard is a complex series of documents, and navigating its complexities, interdependencies, and stakeholder roles (Asset Owner, Product Supplier, System Integrator) is a significant barrier.¹⁷
- **OT vs. IT Disconnect:** Mainstream GRC tools are IT-centric.¹⁹ They fail to address the unique concepts of OT, such as the Purdue Model ²⁰, safety-cybersecurity interactions (e.g., FMEA, RAMS) ²¹, and the lifecycle management of Security Levels (SLs).
- **Manual & Fragmented Processes:** Compliance and risk assessment efforts are typically manual, managed in spreadsheets, and lack collaboration. This leads to a lack of traceability, version control, and a "single source of truth" for audit evidence.⁹

1.2. Proposed Solution

A web-based, multi-tenant SaaS platform, "Cyber-62443-Assure," designed as a "workshop" tool for specialist cybersecurity consultants (Facilitators).

The platform provides a guided, collaborative environment that walks a Facilitator and their clients through the entire IEC 62443 lifecycle, from initial risk assessment to a final, evidence-backed "Security Case."

It functions as an AI-augmented "System of Record" for 62443 compliance. It operationalizes

the standard, ensures traceability, enables real-time collaboration, and provides a centralized, auditable Evidence Locker.⁹

1.3. User Personas and Roles

The system's permissions model will be based on Persona-Based Access Control (PBAC).²² Permissions are determined by the user's *role* (e.g., "Asset Owner") and *context* (e.g., "is currently in the 'Detailed Risk Assessment' phase of Project X"). This is more nuanced than simple RBAC and is essential for the Facilitator-led workflow, ensuring users only see relevant data and actions.²²

This persona-based approach is critical. The platform's UI and available modules must adapt to the user's specific goals. An Asset Owner²³ is focused on 62443-3-2 (Risk Assessment)²⁴ and 62443-2-1 (CSMS)²⁵, while a Product Supplier²⁶ is focused on 62443-4-1 (Secure Development Lifecycle)²⁷ and 62443-4-2 (Component Requirements).⁶ The system must serve both.

Table 1: User Persona Matrix
Purpose: Defines the "who" for the application, guiding UI/UX and PBAC logic.

Persona	Role	Primary Goal	Key Pain Points	Key Platform Modules
Sam (SysAdmin)	Platform Administrator	Manage platform health, tenants, billing, and system-wide credentials.	"I need to provision a new consultant's organization securely." "I must manage shared API keys (Postgres, Neo4j, OpenRouter) without hardcoding them."	Admin Console (User Mgt, Org Mgt, API Credential Mgt) ²⁸

Dr. Aris (Facilitator)	Cybersecurity Consultant ²⁹	"I need to efficiently guide 10 clients through the 62443-3-2 RA process and generate a final report."	"My clients are confused." "Tracking evidence in spreadsheets is a nightmare." "I have to repeat the same explanations for every client."	<i>All Modules.</i> (Project Setup, RA, ZCR, Threat Canvas, Evidence Locker, Reporting)
Marcus (Client)	Asset Owner (Plant Manager) ²³	"I need to understand my risk, achieve a target SL-T, and get a report for my auditor."	"What is a 'Zone'?" "Why am I spending this money?" "Is this safety-critical FMEA ³⁰ related to this 'cyber' thing?"	62443-2-1 (CSMS) & 62443-3-2 (RA) Workflows. ²⁴ (Asset Register, RA, Evidence)
Eva (Client)	Product Supplier (R&D Lead) ²⁶	"I need to certify my new PLC to 62443-4-2 (SL-C 2) by proving my development lifecycle meets 62443-4-1 (SDL)." ²⁷	"The standard is a 100-page PDF." "How do I manage defect/patch lifecycle ⁶ evidence for 50 requirements?"	62443-4-1 (SDL) & 62443-4-2 (Component) Workflows. ⁶ (Requirements Mgt, Evidence)

2. The End-to-End IEC 62443 Workflow: A Visual Journey

2.1. The Workflow "Map" UI

The primary navigation element for any active project shall be a visual, "you are here" map. This fulfills the user's request for a clear, persistent status indicator. This will be a React component resembling a flow diagram.⁷ Each node in the diagram represents a Phase (e.g., "Initial Risk Assessment," "Define Security Levels"). The current phase will be highlighted, and completed phases will be check-marked. When a user logs in, they are taken to their project dashboard, which prominently displays this map, showing *exactly* where they are in the process.

2.2. The Dual-Lifecycle Workflow

The IEC 62443 series is not one workflow but a collection of standards for different stakeholders.¹⁸ The application must reflect this. When a Facilitator creates a new project, the *very first* action must be to select the project's primary goal, which determines the workflow map:

1. **Track A: The System Lifecycle (for Asset Owners / Integrators)** - Focuses on 62443-2-1 (CSMS), 62443-2-4 (Service Providers), and 62443-3-x (System Design).⁵
2. **Track B: The Product Lifecycle (for Product Suppliers)** - Focuses on 62443-4-1 (SDL) and 62443-4-2 (Component Requirements).⁶

The following table details the phases for the more common "Track A: System Lifecycle."

Table 2: IEC 62443 Workflow Map (Track A: System Lifecycle)

Purpose: Defines the application's core logic and navigation map for an Asset Owner's system assessment.

Phase	Key Activity	Governing Standard	Description & Key Features
Phase 1	Scoping & Initial RA	62443-3-2 (ZCR 1, 2) ²⁴	Define the System under Consideration (SuC). ²⁴ Conduct the Initial (High-Level) Risk Assessment (HARA). ²¹ Feature:

			A dedicated UI to ingest FMEA/RAMS data to define impact categories and severity, as HARA assumes worst-case likelihood. ²¹
Phase 2	Partitioning & Threat Model	62443-3-2 (ZCR 3)	Partition the SuC into Zones & Conduits (ZCR).³³ Feature: The "Threat Modeling Canvas" (using React Flow).¹³ Feature: AI-assisted threat elicitation (populating the canvas with threats from MITRE ATT&CK for ICS).³⁴
Phase 3	Asset & Risk Register	62443-3-2 (ZCR 5)	Build the detailed Asset Register (CMDB).³⁵ Conduct the Detailed Risk Assessment (DRA) for high-risk zones identified in Phase 1.²¹ Feature: Assign assets (from the CMDB) to zones (from the canvas).
Phase 4	Define Security Levels	62443-3-2 / 62443-3-3	Based on the DRA, assign a Security Level Target (SL-T) to each Zone and Conduit.²⁴ Feature: The system

			auto-suggests SL-Ts based on risk scores and ingested FMEA impact data.
Phase 5	Apply & Track Controls	62443-3-3 (SRs) / 62443-4-2 (CRs)	The "Requirements Engine." The system generates a checklist of all technical System Requirements (SRs) ³⁷ and Component Requirements (CRs) ³⁸ needed to meet the SL-T for each Zone.
Phase 6	Collect Evidence (SL-A)	N/A	The "Evidence Locker". ⁹ The client team uploads evidence (policies, configs, screenshots) against each SR/CR. Feature: A dashboard tracking SL-T vs. SL-C vs. SL-A. ³⁹
Phase 7	Establish CSMS	62443-2-1 ²⁵	A guided-questionnaire module (like CSET ⁴⁰) to establish the <i>organizational</i> policies (Cyber Security Management System). ⁴¹

Phase 8	Generate Security Case	N/A	Generate the final reports: Asset Register, Risk Assessment, SL-T/SL-A Gap Analysis, CSMS Policy document, and Handover Plan.
---------	------------------------	-----	---

3. Core Feature Specifications (MVP)

The MVP is focused on "a basic design... [to] collects high level design and initial ratings... inputing from RAMS and safety (FmEA)," which maps to Phases 1 and 2 of the workflow.

3.1. Platform Admin Console (SysAdmin Persona)

A secure, isolated Next.js route (/admin) for the SysAdmin persona, built with a modern, dense "engineering style" UI.¹²

- **User/Org Management:** Full CRUD (Create, Read, Update, Delete) for Organizations (Consulting Firms) and Users (Facilitators, Clients).⁴³
- **API Credential Management:** A secure "vault" UI for managing the shared service credentials.²⁸ This is a critical security function and includes encrypted storage for:
 - Postgres Connection String
 - Neo4j URI, User, Password
 - Qdrant API Key and URL
 - OpenRouter.ai API Key⁴⁴
- **AI Configuration (LLM Management):**
 This feature directly implements the user's request for an OpenRouter-powered dropdown. This provides the platform owner (SysAdmin) with crucial control over AI costs and capabilities.⁴⁵
 1. The Admin UI will, on load, make a GET /api/v1/models request to OpenRouter.ai, using the stored API key.⁴⁶
 2. The JSON response, a list of model objects⁴⁷, will be used to populate several dropdown menus on this admin page.
 3. The Admin can then *assign* specific models for specific functions (e.g., Chat

Facilitator Agent, Embedding Agent, Summarization Agent).⁴⁸

4. This configuration is saved to the Postgres DB. When an AI agent is called in the application, it first looks up which model id to use from this configuration. This provides total flexibility, allowing the Admin to swap models (e.g., from GPT-4o to Claude 3.5) without a code change.

Table 3: OpenRouter.ai Model Selection UI Specification

Purpose: To provide a concrete UI specification for LLM management.

Agent Function	UI Element	Model Data (from OpenRouter API)	Saved Config Value (Postgres)
Chat Facilitator	Dropdown Menu	Populated with model name (e.g., "Claude 3.5 Sonnet")	id (e.g., "anthropic/claude-3.5-sonnet")
Threat Elicitation	Dropdown Menu	Populated with model name (e.g., "GPT-4o")	id (e.g., "openai/gpt-4o")
Text Embedding	Dropdown Menu	Populated with model name (e.g., "text-embedding-ada-002")	id (e.g., "openai/text-embedding-ada-002")
GraphRAG Summarizer	Dropdown Menu	Populated with model name (e.g., "Llama 3 70B Instruct")	id (e.g., "meta-llama/llama-3-70b-instruct")

3.2. Module 1: Project Scoping & Initial Risk Assessment (HARA)

This module is a wizard-style UI that guides the Facilitator and Client through 62443-3-2 ZCR 1 & 2.²⁴

- **Step 1: Define System under Consideration (SuC):** A simple text form⁴⁹ asking for Name, Description, Location, and Business/Operational Criticality.²⁴
- **Step 2: Define Impact Categories:**

This is the direct implementation of the "inputting from RAMS and safety (FmEA)" requirement.³⁰ This integration is the key to bridging the safety-cybersecurity gap. The 62443-3-2 Initial Risk Assessment (HARA) method assumes a threat likelihood of one (worst-case scenario).²¹ Therefore, the only variable to assess is impact (consequence). The platform will not ask users to invent this. It will provide a UI to ingest their existing safety analyses.

- **UI:** A form to define impact categories (e.g., Safety, Environmental, Financial, Operational) and their severity (e.g., 1-5). The user will be *prompted* to upload their FMEA, HAZOP, LOPA, or other RAMS documentation³⁰ as the *justification* (evidence) for these ratings.
- **Step 3: Conduct HARA Workshop:** A simple, real-time collaborative table where the team lists high-level assets or functions (e.g., "Boiler Control Loop") and assigns an impact rating (from Step 2) for a worst-case cyber-compromise.⁵⁰ This generates the "initial ratings" for high-risk areas, as requested.²¹

3.3. Module 2: Threat Modeling & ZCR (The Canvas)

This module implements the "canvas" for threat modeling and 62443-3-2 ZCR partitioning.³³

- **Technology Choice:**
The user mentioned draw.io.⁵¹ A simple drawing tool is insufficient. The architecture specifies Neo4j, a graph database.⁵² The canvas component must therefore be React Flow.¹³
This is a critical architectural decision. tldraw⁵⁴ is a whiteboard; it produces a drawing. React Flow⁵⁵ is a node-based diagramming library. Every node and edge drawn on the React Flow canvas⁵⁶ will have a 1:1 mapping to a node and relationship in the Neo4j database.⁵⁷ The canvas is the database. The visual model is the data model. This creates a powerful, persistent, and queryable system model, fulfilling the "CMDB" and "asset list" requirements in a visual-first way.
- **Features:**
 - A full-screen, responsive React Flow component.
 - **Collaborative & Real-time:** Multiple users (Facilitator, Clients) can be on the canvas simultaneously, seeing each other's cursors and updates in near real-time.⁵⁸
 - **ZCR Partitioning:** Users can draw "Zone" boundaries (as parent nodes) and drag-and-drop "Asset" nodes (e.g., PLCs, HMIs, Firewalls) into them.³³ They can draw "Conduit" edges between zones to represent data flows.⁵⁹
 - **AI-Assisted Threat Elicitation:**
 1. The Facilitator right-clicks an Asset node (e.g., "PLC-01").
 2. A context menu appears: "Find applicable threats (MITRE)."
 3. This triggers the GraphRAG AI. The AI queries its knowledge base (built from

MITRE ATT&CK for ICS, which is available as STIX data ⁶⁰).

4. The AI responds: "I recommend adding 'T0851: Service Stop' ⁶¹ and 'T0869: Compromise Firmware' (tactics targeting loss of control ⁶²). Would you like to add these to the threat model?"
5. The Facilitator clicks "Yes," and the AI drops new "Threat" nodes onto the canvas, automatically drawing relationship-edges to the "PLC-01" asset.

4. Core Feature Specifications (V1 Expansion)

This "V1" expansion builds the full compliance engine on top of the MVP's HARA and threat model, addressing the "as we expand" part of the query.

4.1. Module 3: The IACS Asset Register (CMDB)

This module is the "list view" or "database view" of the assets created in the Module 2 "canvas view." It fulfills the "CMDB for software and configuration" and "more comprehensive asset list" requirement.

An OT/ICS asset register is *not* an IT CMDB. It must prioritize attributes relevant to 62443.³⁵ The data model must capture criticality (business, safety, security) ³⁵, physical/logical location ⁶³, and the specific 62443-4-2 component type.³⁸ This data will be "dual-written" or synchronized between Postgres (for fast tabular access) and Neo4j (for graph relationships).

Table 4: Asset Register (CMDB) Schema (Postgres Model)

Purpose: Defines the core data model for all IACS assets in the system.

Column	Type	Description	Example
asset_id	UUID (PK)	Unique identifier	a1b2c3d4-....
project_id	UUID (FK)	Links to the project	p-001
zone_id	UUID (FK)	Links to the Zone (from 62443-3-2) ⁶³	z-001

name	TEXT	Human-readable name	Boiler 1 PLC
asset_type	ENUM	Per 62443-4-2: Embedded Device (ED), Host Device (HD), Network Device (ND), Software Application (SA) ³⁸	Embedded Device (ED)
manufacturer	TEXT	e.g., Rockwell, Siemens	Siemens
model	TEXT		S7-1500
ip_address	INET		192.168.1.10
safety_impact	INT	1-5, from HARA / FMEA ³⁰	5
criticality	ENUM	(Business, Safety, Security) ³⁵	Safety
sl_c	INT	Capability Security Level (0-4). This is the <i>achieved</i> level of the component as-shipped from the vendor.	2

4.2. Module 4: Detailed Risk & Requirements Mapping

This is the "Requirements Engine," the heart of the platform. It addresses the user's reference to the CISA CSET tool.⁶⁴

CSET is a desktop application that provides a systematic, question-based approach to assessing cybersecurity posture against various standards.⁶⁴ However, analysis of CSET's

supported standards shows it is focused on frameworks like NIST SP 800-53, NERC CIP, and others⁶⁶, but *does not* appear to include IEC 62443 in its core library.

Therefore, the platform will not *use* CSET, but will *replicate its functionality* for IEC 62443. We will build our own "question library"⁴⁰ by parsing the *actual* requirements from the standards.

- **Workflow:**

1. The platform's Postgres database will be pre-loaded with every System Requirement (SR) from 62443-3-3⁶ and Component Requirement (CR) from 62443-4-2⁶⁷, tagging each with its associated Security Level (e.g., SL 1, SL 2, SL 3).³⁷
2. The Facilitator completes Phase 4, setting SL-T=3 for "Zone-A."
3. The "Requirements Engine" queries the question library for all SRs from 62443-3-3 that apply to SL 1, 2, and 3.
4. It generates a comprehensive, CSET-style checklist UI for "Zone-A" with all these requirements (e.g., SR 1.1 RE 1: Unique identification, SR 1.1 RE 2: Multifactor auth for untrusted networks).⁶⁹
5. This fulfills the user's request to "apply the sl-T level targets... to track if they are on trak."

4.3. Module 5: Management System & Lifecycle (CSMS & SDL)

This module provides the "Track B" (Product) workflow and the high-level *process* workflow for "Track A" (System).

- For Asset Owners (Track A): 62443-2-1 (CSMS)
This module is a guided questionnaire based on the requirements of IEC 62443-2-1.5 It covers the organizational maturity required to run a secure IACS, including policies, procedures, patch management, and defining roles and responsibilities.²⁵
- For Product Suppliers (Track B): 62443-4-1 (SDL)
This module is the core workflow for the "Track B" project type. It is a guided questionnaire and evidence-collection workflow for the Secure Development Lifecycle (SDL) as defined in 62443-4-1.6 It covers the 8 practice areas: Secure Design, Secure Implementation (coding guidelines), Verification & Validation, Defect Management, Patch Management, and Product End-of-Life.²⁷

4.4. Module 6: The "Evidence Locker" & Security Case

This module addresses the "evidence collected" and "SL-A (with evidence)" requirements.

This is the core of the GRC (Governance, Risk, and Compliance) function.

Manual, spreadsheet-based evidence collection is a primary failure point in audits.¹¹ The platform *must* be a "single source of truth"¹⁰ and a "centralized evidence repository".⁹

- **UI/UX Workflow:**

1. A user is on the "Requirements" checklist (from Module 4).
2. They see the requirement SR 1.3: Account management.⁶⁹
3. Next to it is a button: "Add Evidence."
4. Clicking this opens a modal where they can upload a file (e.g., Policy-User-Access.pdf), link to an external system (e.g., a ServiceNow ticket or GitHub commit⁷¹), or write a comment.
5. This evidence is now programmatically "tagged" to SR 1.3.
6. The Facilitator can then review this evidence and mark SR 1.3 as "Achieved" (SL-A).
7. This creates the immutable, auditable link between a requirement, the proof, and the final Achieved Security Level (SL-A).

This data populates the primary gap analysis report, which tracks the three different Security Levels³⁹:

- **SL-T (Target):** The *goal*. What the risk assessment (Phase 4) determined is necessary.
- **SL-C (Capability):** The *tool*. The inherent security level of a component, as certified by the vendor (e.g., a PLC is 62443-4-2 SL-C 2).⁶
- **SL-A (Achieved):** The *reality*. The security level achieved by the system *as-implemented*, including compensating controls and evidence (Phase 6).

Table 5: Compliance Tracking Dashboard (SL-T vs. SL-C vs. SL-A)

Purpose: This is the primary "gap analysis" report for the client.

Zone / Component	SL-T (Target)	SL-C (Capability)	SL-A (Achieved)	Status	Gap Analysis
Zone-A (SIS)	3	2	1	Non-Compliant	SL-A < SL-T. Missing SRs for SL2, SL3.
Zone-B (DCS)	2	2	2	Compliant	SL-A = SL-T.
PLC-01 (in	2	2	N/A	Compliant	Component

Zone-B)					's capability (SL-C) meets target (SL-T).
FW-01 (in Zone-B)	2	3	N/A	Compliant	Component 's capability (SL-C) exceeds target (SL-T).

4.5. Platform-Wide Collaborative Features

- **Real-time Multi-user:**
This is for the "workshop stule" and "multiple people... imultnalesously" requirement. As detailed in the architecture (Part III), this will be handled by a managed WebSocket service like Supabase Realtime.¹⁴ This enables collaborative editing of the canvas, HARA tables, and checklists.
- **In-App Commenting:**
To be useful, comments cannot be a simple global chat. They must be contextual.⁷³
 1. **Canvas Comments:** Users can drop a pin (like Figma) on the React Flow canvas and leave a comment (e.g., "Is this firewall configured correctly?").⁷⁴
 2. **Requirement Comments:** Every SR/CR in the Module 4 checklist will have its own comment thread.
 3. **Evidence Comments:** Every piece of evidence in Module 6 will have a review/comment thread.
 4. @mentions and emoji reactions⁷⁵ will be supported to foster collaboration.
- **Facilitator Gating & Approval Workflow:**
This implements the "Faciliator is in chargee and will procede" directive.
 - **UI/UX:** The system will use standard workflow patterns.⁷
 - Clients (Asset Owners, Suppliers) will see a "Submit Phase for Review" button at the end of each Phase.⁷⁶
 - This action locks the phase's content (making it read-only) and sends a notification to the Facilitator.⁸
 - The Facilitator (and *only* the Facilitator) will see "Approve & Advance" and "Reject with Comments" buttons, creating a formal, auditable gate for all project

progression.⁷

5. Development Strategy & MVP Roadmap

The user provides a clear, logical phasing. The MVP establishes the "problem" (HARA, Threat Model), and V1 builds the "solution" (CMDB, Requirements Engine, Evidence). This is a sound agile roadmap.⁷⁸

Table 6: Feature Prioritization (MVP vs. V1)
Purpose: To provide a clear, actionable roadmap for the development team.⁷⁸

Feature	MVP (Month 1-3)	V1 (Month 4-9)
Platform	Admin Console ⁴² , Org/User Mgt, shadcn/ui shell ¹²	Multi-Tenancy, Full Reporting Engine
Collaboration	Basic login, Real-time canvas (via Supabase) ⁵⁸	Contextual Comments ⁷³ , Facilitator Gating ⁷
62443 Workflow	Module 1: Scoping & HARA ²¹ Module 2: Threat Canvas (React Flow) ¹³	Module 3: CMDB ³⁵ Module 4: Requirements Engine ³⁷ Module 5: CSMS / SDL ²⁵ Module 6: Evidence Locker ⁹
AI (GraphRAG)	Ingest 62443/MITRE data. AI-assisted Threat Elicitation (on canvas) ³⁴	AI-assisted Requirement Answering (RAG) AI-driven Gap Analysis Summarization
Databases	Postgres (User, Project), Neo4j (Nodes), Qdrant	Schema optimization, data synchronization services

	(Embeds)	
--	----------	--

Part III: System Architecture & Implementation Blueprint

This section details the "how," providing the architectural blueprint for the development team.

1. Architectural Philosophy: Polyglot Persistence for GraphRAG

The specified stack (Postgres, Neo4j, Qdrant) is a deliberate choice for a **Polyglot Persistence** architecture.⁸¹ The core principle is using the *right tool for the right job*⁸¹, as no single database can efficiently handle all data shapes (relational, graph, vector).

- **Why Postgres?** It is the "System of Record" for structured, relational data (users, orgs, projects) that requires high integrity and ACID compliance.⁸¹
- **Why Neo4j?** It is the "Relationship Engine." An IACS model is a graph. Modeling the many-to-many relationships between assets, threats, zones, and controls in Postgres would be a nightmare of JOIN tables. A graph database (Neo4j) is built to traverse these complex relationships instantly.⁸²
- **Why Qdrant?** It is the "Knowledge Engine." It is a vector database built for high-performance similarity search.⁸³ It allows the platform to perform fast, semantic search on unstructured text (62443 standards, MITRE threats, CSET questions, uploaded evidence).

This specific combination (Neo4j + Qdrant + LLM) is the precise architecture for **GraphRAG**.⁵² This allows the platform to answer questions by *first* finding semantically similar concepts (Qdrant) and *then* exploring the contextual relationships of those concepts (Neo4j).⁸⁴ This provides a far more sophisticated and accurate AI capability than simple RAG.⁸⁵

2. Data & Application Architecture

2.1. Database Strategy

The databases are "shared" at the infrastructure layer but will be accessed by dedicated services.

- **Postgres (Shared):** The "System of Record" for structured, relational data.
 - **Schemas:** Organizations, Users, Roles (PBAC), Projects, Asset_Register (CMDB Table)³⁵, Zone_Register⁶³, Requirements_Library (parsed from 62443-3-3/4-2)³⁷, Evidence_Locker (metadata, links to S3/blob storage)⁹, Comments.
- **Neo4j (Shared):** The "Relationship Engine." This is our graph model.
 - **Node Labels:** (:Project), (:Asset {asset_id}), (:Zone {zone_id}), (:Threat {mitre_id}), (:Control {sr_id}), (:Evidence {evidence_id}).
 - **Relationships:** (:Asset)-->(:Zone), (:Zone)-->(:Zone), (:Threat)-->(:Asset), (:Control)-->(:Threat), (:Evidence)-->(:Control).
- **Qdrant (Shared):** The "Knowledge Engine" (Vector Store).
 - **Collections:**
 1. iec_62443_standards: Embeddings of every SR, CR, and guidance paragraph.
 2. mitre_attck_ics: Embeddings of all ICS tactics and techniques.⁶⁰
 3. project_evidence: Embeddings of user-uploaded evidence text (for semantic search).

2.2. Application Stack

- **Frontend:** A dedicated Next.js application using the App Router.⁸⁶ This is a "thick client" architecture.
- **UI:** shadcn/ui¹² and Tailwind CSS for rapid, "engineering style," accessible component development.⁸⁷
- **Deployment:** Vercel (or similar serverless platform) for the Next.js application.

2.3. Real-Time Service

- **The Problem:** The user's stack (Next.js) and requirement (real-time, multi-user) are in conflict. Serverless functions (like Vercel's) are stateless and have short timeouts (e.g., 10s).⁸⁶ They are fundamentally unsuitable for hosting persistent WebSocket

connections.⁸⁸

- **The Architectural Solution:** Do not self-host. A managed WebSocket service is required.
 - Self-hosting a Socket.IO server⁸⁹ adds a new, stateful, complex piece of infrastructure to manage.
 - Managed services like Ably or Pusher are excellent but add another vendor and cost center.¹⁴
 - The user has specified *shared Postgres*. **Supabase** is a platform built on Postgres and *includes* Supabase Realtime, which provides WebSocket-based "presence" (who is online), "broadcast" (pub/sub), and database change listening.¹⁴
 - **Decision:** The most architecturally-consistent, pragmatic, and simple solution is to leverage the existing Postgres infrastructure by using **Supabase Realtime**. The Next.js client will connect to Supabase to broadcast and receive real-time updates for the canvas, comment threads, and workshop checklists.

3. AI Facilitation Architecture: Implementing GraphRAG

This section details the AI facilitation, built using the specified stack.⁵²

3.1. Ingestion Pipeline (One-Time Setup)

A set of scripts will be run to populate the knowledge base:

1. Parse the 62443-3-3 (SRs), 62443-4-2 (CRs) standards documents into discrete text chunks.
2. Parse the MITRE ATT&CK for ICS STIX data⁶⁰ into text chunks.
3. For each chunk, use the Embedding Agent model (selected in the Admin Console, via OpenRouter.ai) to generate a vector.
4. Store these vectors and their source metadata in their respective Qdrant collections.⁵²
5. Simultaneously, parse the *relationships* (e.g., "SR 1.1 RE 1" is part of "FR 1") and store them as nodes and edges in Neo4j.⁵²

3.2. Retrieval Pipeline (The Live AI Facilitation)

This pipeline is triggered by user actions (e.g., "AI, suggest threats for this asset"). It demonstrates the power of GraphRAG.⁸⁴

Example Workflow:

- 1. **User Prompt:** Facilitator right-clicks "Zone-A (SL-T=3)" and asks the AI: "Which requirements for 'Use Control' (FR 2) are we missing evidence for?"
- 2. **Step 1 (Qdrant - Vector Search):** The application backend queries the iec_62443_standards collection in Qdrant for "Use Control FR 2 requirements for SL 3." Qdrant returns the top-k matching sr_ids (e.g., SR 2.1, SR 2.2, SR 2.3 RE 1).⁸⁴
- 3. **Step 2 (Neo4j - Graph Traversal):** The application takes these sr_ids (the "seed points") and queries the Neo4j graph for the current project's context 82:
MATCH (c:Control)--(e:Evidence) WHERE c.sr_id IN AND c.project_id = 'p-001' RETURN c.sr_id, e.evidence_id
- 4. **Step 3 (Context Building):** Neo4j reveals that SR 2.1 and SR 2.2 have PROVES relationships, but SR 2.3 RE 1 *does not*.
- 5. **Step 4 (LLM Generation via OpenRouter):** This structured context is passed to the Chat Facilitator LLM (via the POST /api/v1/chat/completions endpoint ⁹⁰): "You are a 62443 expert. The user asked for missing 'Use Control' evidence for Zone-A (SL-T 3). Qdrant identified SR 2.1, 2.2, and 2.3 RE 1 as relevant. Our Neo4j graph shows evidence exists for 2.1 and 2.2, but not for 2.3 RE 1. Formulate a helpful response."
- 6. **AI Response:** "For Zone-A (SL-T 3), you are missing evidence for **SR 2.3 RE 1 (Audit log protection)**. You have already provided evidence for SR 2.1 and SR 2.2."

Table 7: AI Facilitation: Sample GraphRAG Queries
Purpose: To demonstrate the practical value of the GraphRAG architecture.⁵²

User Action / Prompt	Qdrant Query (Semantic Search)	Neo4j Query (Graph Traversal)	AI-Generated Insight
Right-click PLC-01 -> "Suggest Threats"	Find MITRE techniques related to "PLC compromise". ⁶⁰	MATCH (t:Threat)-->(a:Asset {id:'plc-01'}) RETURN t.name	"I see PLC-01 has no associated threats. Based on MITRE ATT&CK for ICS ⁶² , I recommend adding 'T0851: Service Stop' and 'T0869: Compromise Firmware'. ^{61"}

"What is the risk impact of this threat?"	Find FMEA/HARA data related to this threat's consequence.	MATCH (t:Threat {id:'T0851'})-->(a:Asset)-->(z:Zone) RETURN a.safety_impact, z.name	"The threat 'Service Stop' (T0851) targets PLC-01. Your HARA (from Phase 1) ²¹ defined this asset as having a Safety Impact of 5 (Critical) . This is a high-priority risk."
"What controls mitigate this threat?"	Find 62443 controls (SRs/CRs) semantically related to "Service Stop."	MATCH (c:Control)-->(t:Threat {id:'T0851'}) RETURN c.sr_id	"To mitigate 'Service Stop', IEC 62443-3-3 recommends SR 7.1 (Denial of service protection) and SR 3.2 (Malicious code protection) . ³⁷ Would you like to add these to your requirements list?"

Part IV: Commercialization & Go-to-Market (GTM) Strategy

A comprehensive PRD must also define the product's market viability, target customer, and pricing model.⁹¹

1. Go-to-Market Strategy

1.1. Target Market & Segmentation

This GTM is *not* a broad-reach B2B SaaS strategy. It is a highly-focused, "vertical SaaS" strategy.⁹²

The product is complex and assumes expert-level knowledge (IEC 62443). The "Facilitator" persona is the *key* to the entire workflow. Therefore, the primary GTM target ⁹¹ is *not* the end-user (Asset Owner), but the *channel* to the end-user: **Specialist Cybersecurity Consulting Firms** and **Certified System Integrators**.⁹³

This is a **sales-led GTM motion**.⁹³ The product is high-value, high-complexity, and high-contract-value. It is not a self-service, product-led-growth (PLG) tool.

1.2. Marketing & Sales Strategy

- **Trust-Based Marketing:** The cybersecurity community is skeptical. Marketing must be "for experts, by experts."
 - **Content:** Technical white papers on the platform's GraphRAG implementation ⁵², webinars demonstrating the FMEA-to-Risk-Assessment workflow ³⁰, and case studies.
 - **Trust Badges:** The platform must demonstrate its own compliance. The marketing site will feature "trust badges" (e.g., ISO 27001, SOC 2).⁹⁴
- **Sales:** A direct, high-touch sales team will target known cybersecurity consulting practices. The ideal sales targets are thought leaders and members of bodies like the ISA Global Cybersecurity Alliance (ISAGCA).¹⁸

2. Pricing & Packaging Model

2.1. Recommended Model

GRC software pricing is complex.⁹⁵ A simple per-user model ⁹⁷ is insufficient because the value is not in the number of users, but in the number of *projects* a consultant can manage.

The platform's value is enabling a consultant to run their entire business more efficiently. This

leads to a **Hybrid Tiered Model** ⁹⁸:

- **Base Metric:** Per-Facilitator-Seat (the consultant)
- **Usage Metric:** Per-Active-Project (or Per-Client-Guest-User)

This model aligns price with the value the consultant extracts.¹⁰⁰ A consultant with 10 active projects pays more than one with 2.

2.2. Value-Based Pricing Justification

The platform is not a "cheaper GRC tool." It is a force-multiplier for high-end consultants. The unique value propositions are:

1. **Efficiency:** The AI Facilitator (GraphRAG) and pre-built 62443 workflows (CSET-model) allow a consultant to automate mundane tasks and double their project throughput.
2. **Expertise:** The platform *is* an expert, embedding the 62443 standard, MITRE ATT&CK, and FMEA integration into a single tool.

The pricing will reflect this high-value, high-margin service.¹⁰¹

Table 8: Proposed Pricing Tiers (B2B SaaS)
Purpose: To define the GTM pricing strategy.⁹⁸

Tier	Price (Annual)	Target Audience	Core Metrics	Key Features
Professional	\$10,000 / year	Individual Consultant / Small Firm	1 Facilitator Seat 5 Client "Guest" Seats 3 Active Projects	Core 62443-3-2 & 62443-2-1 Workflows Threat Modeling Canvas Evidence Locker Basic AI

				Facilitation
Enterprise	\$40,000 / year	Mid-Large Consulting Firm	5 Facilitator Seats 50 Client "Guest" Seats Unlimited Active Projects	All "Professional" features + 62443-4-1 / 4-2 Supplier Workflows White-label Reporting API Access (for evidence automation) ¹⁰
Supplier	Contact for Pricing	Product Supplier (e.g., Siemens, Rockwell)	N/A (Internal Site License)	A-la-carte module: 62443-4-1 (SDL) & 62443-4-2 (CR) workflows only. (Used for internal product certification)

Works cited

1. Applied BMAD - Reclaiming Control in AI Development - Benny's Mind Hack, accessed November 12, 2025, <https://bennycheung.github.io/bmad-reclaiming-control-in-ai-dev>
2. Spec vs Vibe. BMAD vs Spec Kit - Fokker Chartier - Medium, accessed November 12, 2025, <https://fokker.medium.com/spec-vs-vibe-bmad-vs-spec-kit-47a471ba718b>
3. BMAD: The AI Development Secret No One's Talking About (Actually... Everyone is) | by Vishal Mysore | Medium, accessed November 12, 2025, <https://medium.com/@visrow/bmad-the-ai-development-secret-no-ones-talking-about-actually-everyone-is-9c1cabce8a10>
4. Structuring the ISA/IEC 62443 Standards - ISA Global Cybersecurity Alliance,

- accessed November 12, 2025,
<https://gca.isa.org/blog/structuring-the-isa-iec-62443-standards>
5. All you need to know about ISA/IEC 62443 Standard - Payatu, accessed November 12, 2025,
<https://payatu.com/wp-content/uploads/2022/08/isa-iec-62443-standard.pdf>
 6. The Essential Guide to the IEC 62443 industrial cybersecurity standards, accessed November 12, 2025,
<https://industrialcyber.co/features/the-essential-guide-to-the-iec-62443-industrial-cybersecurity-standards/>
 7. Fusion Help | Change order approval overview - Autodesk product documentation, accessed November 12, 2025,
<https://help.autodesk.com/view/fusion360/ENU/index.html?guid=MNG-CO-WORKFLOW>
 8. How to create an approval workflow for your team - Wrike, accessed November 12, 2025, <https://www.wrike.com/blog/how-to-create-approval-workflow/>
 9. Evidence Collection for Compliance - RegScale, accessed November 12, 2025,
<https://regscale.com/evidence-collection/>
 10. Automated to AI-Powered Evidence Collection in Compliance - Strike Graph, accessed November 12, 2025,
<https://www.strikegraph.com/blog/ai-compliance-evidence-collection>
 11. 3 Tips to Radically Reduce Your Evidence Management Burden - Hyperproof, accessed November 12, 2025,
<https://hyperproof.io/resource/evidence-management-tips/>
 12. The Foundation for your Design System - Shadcn UI, accessed November 12, 2025, <https://ui.shadcn.com/examples/dashboard>
 13. Whiteboard Features - React Flow, accessed November 12, 2025,
<https://reactflow.dev/learn/advanced-use/whiteboard>
 14. Looking for a realtime multiuser library / framework. : r/node - Reddit, accessed November 12, 2025,
https://www.reddit.com/r/node/comments/xibmou/looking_for_a_realtime_multiuser_library_framework/
 15. Feedback: BMad needs feature-driven approach and agent coordination (real usage on brownfield project) #446 - GitHub, accessed November 12, 2025,
<https://github.com/bmad-code-org/BMAD-METHOD/issues/446>
 16. A Practical Approach to Adopting the IEC 62443 Standards, accessed November 12, 2025,
<https://gca.isa.org/blog/a-practical-approach-to-adopting-the-iec-62443-standards>
 17. The IEC 62443 Series of Standards: How to Defend Against Infrastructure Cyberattacks, accessed November 12, 2025,
<https://www.analog.com/en/signals/thought-leadership/the-iec-62443-series-of-standards-how-to-defend.html>
 18. ISA/IEC 62443 Series of Standards | ISAGCA, accessed November 12, 2025,
<https://isagca.org/isa-iec-62443-standards>
 19. Top 18 GRC (Governance, Risk & Compliance) Tools in 2025 | Pathlock, accessed

November 12, 2025,

<https://pathlock.com/blog/grc/list-of-top-grc-tools-and-softwares/>

20. Understanding ISA/IEC 62443: A Guide for OT Security Teams - Dragos, accessed November 12, 2025, <https://www.dragos.com/blog/isa-iec-62443-concepts>
21. Cybersecurity Risk Assessment According to ISA/IEC 62443-3-2, accessed November 12, 2025, <https://gca.isa.org/blog/cybersecurity-risk-assessment-according-to-isa-iec-62443-3-2>
22. Enterprise Guide To: Persona-Based Access Controls - Knostic, accessed November 12, 2025, <https://www.knostic.ai/blog/persona-based-access-control-pbac>
23. The Three User Personas of Advanced Industrial Analytics Software - LNS Research, accessed November 12, 2025, <https://blog.lnsresearch.com/the-three-user-personas-of-advanced-industrial-analytics-software>
24. A Practical Guide to Risk Assessment in ICS/OT using IEC 62443-3.2 | by Sathish - Medium, accessed November 12, 2025, <https://medium.com/@sathish95/a-practical-guide-to-risk-assessment-in-ics-ot-using-iec-62443-3-2-c3fb43471e67>
25. Announcing General Availability of ISA/IEC 62443-2-1 Workflow in the SecurityGate Platform, accessed November 12, 2025, <https://securitygate.io/blog/isa-iec-62443-2-1/>
26. TÜV Rheinland Certifies Schneider Electric's Secure Development Lifecycle Process to ISA/IEC 62443-4-1, accessed November 12, 2025, <https://www.se.com/ww/en/about-us/newsroom/news/press-releases/t%C3%BCv-rheinland-certifies-schneider-electric%E2%80%99s-secure-development-lifecycle-process-to-isa-iec-62443-4-1-5da9d78d8c5665197877d7c7>
27. IEC 62443-4-1:2018, accessed November 12, 2025, <https://webstore.iec.ch/en/publication/33615>
28. UX Design Case: Database Credential Management | by Geoff Nelowet - Medium, accessed November 12, 2025, <https://medium.com/nyc-design/ux-design-case-database-credential-management-58ae16753b6b>
29. Cybersecurity GRC Powered by On-Demand CRQ - Kovrr, accessed November 12, 2025, <https://www.kovrr.com/cybersecurity-grc>
30. Is FMEA suitable for cyber risk analysis?, accessed November 12, 2025, <https://www.c-risk.com/blog/fmea>
31. IEC 62443 - SDLA Certification - ISASecure, accessed November 12, 2025, <https://isasecure.org/certification/iec-62443-sdla-certification>
32. Using IEC 62443 to Secure OT Systems: The Ultimate Guide - Verve Industrial, accessed November 12, 2025, <https://verveindustrial.com/resources/blog/the-ultimate-guide-to-protecting-ot-systems-with-iec-62443>
33. Understanding IEC 62443-3-2 Zones, Conduits, and Risk Assessments | Novesh, accessed November 12, 2025,

- <https://novesh.com/blog/novesh-blog-7/understanding-iec-62443-3-2-zones-conduits-and-risk-assessments-27>
34. Threat Modeling With ATT&CK, accessed November 12, 2025, <https://ctid.mitre.org/projects/threat-modeling-with-attack/>
 35. Principle 3: Identify and categorise assets to support... - NCSC.GOV.UK, accessed November 12, 2025, <https://www.ncsc.gov.uk/collection/operational-technology/definitive-architecture-view/principle-3>
 36. IEC 62443 Zones and Conduits: A Practical Approach to Segmentation - InstruNexus, accessed November 12, 2025, <https://instrunexus.com/iec-62443-zones-and-conduits-a-practical-approach-to-segmentation/>
 37. What is IEC/ISA 62443-3-3:2013? Cybersecurity & Compliance | UpGuard, accessed November 12, 2025, <https://www.upguard.com/blog/isa-62443-3-3-2013>
 38. IEC 62443-4-2, the need to secure components | INCIBE-CERT, accessed November 12, 2025, <https://www.incibe.es/en/incibe-cert/blog/iec-62443-4-2-need-secure-components>
 39. IEC/ANSI 62443 Example 1 - SL-A to SL-T Basic Component - IriusRisk, accessed November 12, 2025, <https://www.iriusrisk.com/resources-blog/62443-example-1-sl-a-to-sl-t-basic-component>
 40. CISA's Cybersecurity Evaluation Tool (CSET), accessed November 12, 2025, <https://www.cisa.gov/sites/default/files/publications/2020-seminars-cset-508.pdf>
 41. How to conduct an IEC 62443-based assessment for metro rail infrastructure - Shieldworkz, accessed November 12, 2025, <https://shieldworkz.com/blogs/how-to-conduct-an-iec-62443-based-assessment-for-metro-rail-infrastructure>
 42. 8 Admin UI Design Tips - Budibase, accessed November 12, 2025, <https://budibase.com/blog/app-building/admin-ui/>
 43. How to Create a Good Admin Panel: Design Tips & Features List - Aspirity, accessed November 12, 2025, <https://aspirity.com/blog/good-admin-panel-design>
 44. OpenRouter Quickstart Guide | Developer Documentation, accessed November 12, 2025, <https://openrouter.ai/docs/quickstart>
 45. LLM Management - Tyk Documentation, accessed November 12, 2025, <https://tyk.io/docs/ai-management/ai-studio/llm-management>
 46. List all models and their properties | OpenRouter | Documentation, accessed November 12, 2025, <https://openrouter.ai/docs/api-reference/models/get-models>
 47. OpenRouter Models | Access 400+ AI Models Through One API, accessed November 12, 2025, <https://openrouter.ai/docs/overview/models>
 48. LLM Management - Katonic Docs, accessed November 12, 2025, <https://docs.katonic.ai/Global/LLM-Management>
 49. ISA/IEC 62443-3-3 Questionnaire (Free Template) - UpGuard, accessed

November 12, 2025,

<https://www.upguard.com/blog/free-template-isa-iec-62443-3-3-questionnaire>

50. Practical Guide to Performing Risk Assessment as per IEC 62443-3-2 and NIST 800-30, accessed November 12, 2025,
<https://hardhatsecurity.com/2024/05/15/practical-guide-to-performing-high-and-detailed-level-risk-assessment-as-per-iec-62443-3-2-and-nist-800-30/>
51. Introducing ThreatCanvas 2.0: Revolutionizing Threat Modeling | SecureFlag, accessed November 12, 2025,
<https://blog.secureflag.com/2024/11/26/threatcanvas-revolutionizing-threat-modeling/>
52. GraphRAG with Qdrant and Neo4j, accessed November 12, 2025,
<https://qdrant.tech/documentation/examples/graphrag-qdrant-neo4j/>
53. Collection of Diagrams to Use in Your React App for Effective Data Visualization, accessed November 12, 2025,
<https://dev.to/plazarev/collection-of-diagrams-to-use-in-your-react-app-for-effective-data-visualization-4o7n>
54. tldraw/tldraw: very good whiteboard SDK / infinite canvas SDK - GitHub, accessed November 12, 2025, <https://github.com/tldraw/tldraw>
55. React Flow: Node-Based UIs in React, accessed November 12, 2025,
<https://reactflow.dev/>
56. Quick Start - React Flow, accessed November 12, 2025,
<https://reactflow.dev/learn>
57. 2024 React and Neo4j - How do I visualize graphs in a React UI - Reddit, accessed November 12, 2025,
https://www.reddit.com/r/Neo4j/comments/1c4d29b/2024_react_and_neo4j_how_do_i_visualize_graphs_in/
58. Socket.IO vs Supabase Realtime: which should you choose in 2025?, accessed November 12, 2025, <https://ably.com/compare/socketio-vs-supabase>
59. Complete Guide to ISA/IEC 62443-3-2: Risk Assessments for Industrial Automation and Control Systems - Security Boulevard, accessed November 12, 2025,
<https://securityboulevard.com/2024/04/complete-guide-to-isa-iec-62443-3-2-risk-assessments-for-industrial-automation-and-control-systems/>
60. ATT&CK Data & Tools, accessed November 12, 2025,
<https://attack.mitre.org/resources/attack-data-and-tools/>
61. MITRE ATT&CK for ICS - Dragos, accessed November 12, 2025,
<https://www.dragos.com/mitre-attack-for-ics>
62. ICS Techniques - MITRE ATT&CK®, accessed November 12, 2025,
<https://attack.mitre.org/techniques/ics/>
63. Zones and conduits, protecting our industrial network | INCIBE-CERT, accessed November 12, 2025,
<https://www.incibe.es/en/incibe-cert/blog/zones-and-conduits-protecting-our-industrial-network>
64. Cyber Security Evaluation Tool (CSET) - CISA, accessed November 12, 2025,
<https://www.cisa.gov/resources-tools/services/cyber-security-evaluation-tool-cs>

et

65. Downloading and Installing CSET - CISA, accessed November 12, 2025, <https://www.cisa.gov/downloading-and-installing-cset>
66. Cyber Security Evaluation Tool (CSET), accessed November 12, 2025, <https://www.hsdll.org/c/view?docid=695539>
67. IEC 62443-4-2:2019, accessed November 12, 2025, <https://webstore.iec.ch/en/publication/34421>
68. ANSI/ISA 62443-4-2-2018 - Security for industrial automation and control systems, Part 4-2: Technical security requirements for IACS components - ANSI Webstore, accessed November 12, 2025, <https://webstore.ansi.org/standards/isa/ansiisa624432018-1717607>
69. Effective ICS Cybersecurity Using the IEC 62443 Standard - Fortinet, accessed November 12, 2025, <https://www.fortinet.com/content/dam/fortinet/assets/analyst-reports/report-san-s-cybersecurity-iec-62443.pdf>
70. An Overview of ISA/IEC 62443-4-1 and Its Supply Chain Requirements, accessed November 12, 2025, https://21577316.fs1.hubspotusercontent-na1.net/hubfs/21577316/ISA%20SBOM%20Presentation_20231101.pdf
71. Automating evidence collection for regulatory compliance: Tools & best practices, accessed November 12, 2025, <https://www.trustcloud.ai/security-questionnaires/automating-evidence-collection-for-regulatory-compliance-tools-best-practices/>
72. GRC Best Practices for Streamlining Compliance Workflows and Security Transparency, accessed November 12, 2025, <https://vendict.com/blog/grc-best-practices-for-streamlining-compliance-workflows-and-security-transparency>
73. How to build an engaging in-app commenting experience | Liveblocks blog, accessed November 12, 2025, <https://liveblocks.io/blog/how-to-build-an-engaging-in-app-commenting-experience>
74. Collaborative Feedback App for UI/UX Design Teams: Boost Productivity & Communication, accessed November 12, 2025, <https://www.commented.io/feature/chat-web-site-startup-ui-ux-design-ga>
75. How to make collaboration apps human centered | by Eve Weinberg - UX Collective, accessed November 12, 2025, <https://uxdesign.cc/ux-breakdown-of-the-best-collaboration-apps-1619767c102c>
76. Streamlining Faculty Approvals: Designing a Digital Approval System to Improve Efficiency and Reduce Frustration | by Goutham Krishna - UX Designer, accessed November 12, 2025, <https://gouthamkrishnapkr.medium.com/streamlining-faculty-approvals-designing-a-digital-approval-system-to-improve-efficiency-and-a98714017b9c>
77. Flow Designer Approvals Overview - Workflow Automation Center of Excellence, accessed November 12, 2025, <https://www.servicenow.com/community/workflow-automation-articles/flow-designer>

- [gner-approvals-overview-workflow-automation-center-of/ta-p/2528202](#)
78. MVP Development Roadmap: Key Milestones and Deliverables - F22 Labs, accessed November 12, 2025, <https://www.f22labs.com/blogs/mvp-milestones-deliverables/>
 79. How to Build a SaaS MVP: The Complete Founder's Guide - DevSquad, accessed November 12, 2025, <https://devsquad.com/blog/saas-mvp>
 80. Agile Software Acquisition Guidebook - DAU, accessed November 12, 2025, <https://www.dau.edu/sites/default/files/Migrated/CopDocuments/AgilePilotsGuidebook%20V1.0%2027Feb20.pdf>
 81. Polyglot Persistence Architectures: When to Use Multiple Database Types - Dev3lop, accessed November 12, 2025, <https://dev3lop.com/polyglot-persistence-architectures-when-to-use-multiple-database-types/>
 82. Implementing Graph RAG Using Knowledge Graphs - IBM, accessed November 12, 2025, <https://www.ibm.com/think/tutorials/knowledge-graph-rag>
 83. Integrate Qdrant and Neo4j to Enhance Your RAG Pipeline - Graph Database & Analytics, accessed November 12, 2025, <https://neo4j.com/blog/developer/qdrant-to-enhance-rag-pipeline/>
 84. GraphRAG: How Lettria Unlocked 20% Accuracy Gains with Qdrant and Neo4j, accessed November 12, 2025, <https://qdrant.tech/blog/case-study-lettria-v2/>
 85. Polyglot Persistence: A Strategic Approach to Modern Data Architecture - Medium, accessed November 12, 2025, <https://medium.com/@rachoork/polyglot-persistence-a-strategic-approach-to-modern-data-architecture-e2a4f957f50b>
 86. The Ultimate Guide to Software Architecture in Next.js: From Monolith to Microservices, accessed November 12, 2025, https://dev.to/shayan_saed/the-ultimate-guide-to-software-architecture-in-nextjs-from-monolith-to-microservices-i2c
 87. shadcn-dashboard · GitHub Topics, accessed November 12, 2025, <https://github.com/topics/shadcn-dashboard>
 88. Using web sockets on Next.js | NO third party solution - YouTube, accessed November 12, 2025, https://www.youtube.com/watch?v=9DEvkYB5_A4
 89. Beyond REST: Building Real-time Collaborative Web Apps with Next.js, WebSockets, and the Edge | by Divyansh Sharma | Medium, accessed November 12, 2025, <https://medium.com/@divyanshsharma0631/beyond-rest-building-real-time-collaborative-web-apps-with-next-js-websockets-and-the-edge-67d90a9f357c>
 90. OpenRouter API Reference | Complete API Documentation, accessed November 12, 2025, <https://openrouter.ai/docs/api-reference/overview>
 91. A No-BS Guide to B2B SaaS Go-To-Market Strategies | Stratabeat, accessed November 12, 2025, <https://stratabeat.com/b2b-saas-gtm-strategy/>
 92. Cybersecurity Marketing Guide: 10 GTM Strategies for 2025 - CyberNewswire, accessed November 12, 2025, <https://cybernewswire.com/blog/cybersecurity-marketing/>
 93. Go-to-Market Strategy for Cybersecurity SaaS Startup: The Complete Playbook,

- accessed November 12, 2025,
<https://cmo-fractional.com/gtm-strategy-for-cybersecurity-saas-startup/>
94. A Proven Cybersecurity SaaS Marketing Strategy (And Mistakes To Avoid),
accessed November 12, 2025,
<https://www.poweredbysearch.com/blog/cybersecurity-saas-marketing-strategy/>
95. How Much Does GRC Implementation Cost in 2024 - Cyber Sierra, accessed
November 12, 2025,
<https://cybersierra.co/blog/how-much-does-grc-implementation-cost-in/>
96. The Top GRC Software of 2024: Expert Reviews & Comparisons - ZenGRC,
accessed November 12, 2025,
<https://www.zengrc.com/blog/the-top-grc-software-of-2024-expert-reviews-comparisons/>
97. 8 Examples of SaaS Pricing Models to Drive Your Success - Thales, accessed
November 12, 2025,
<https://cpl.thalesgroup.com/software-monetization/saas-pricing-models-examples>
98. Your Ultimate Guide to SaaS Pricing Models - Revenera, accessed November 12,
2025,
<https://www.revenera.com/blog/software-monetization/saas-pricing-models-guide/>
99. GRC software licensing models and how to get the best deal - 6clicks, accessed
November 12, 2025,
<https://www.6clicks.com/resources/blog/grc-software-licensing-models-and-how-to-get-the-best-deal>
100. Mastering Competitive Advantage: Building a Profitable B2B Pricing Strategy,
accessed November 12, 2025,
<https://www.dawgen.global/mastering-competitive-advantage-building-a-profitable-b2b-pricing-strategy/>
101. B2B Pricing Consulting and Strategy Services | BCG, accessed November 12,
2025,
<https://www.bcg.com/capabilities/pricing-revenue-management/b2b-pricing>
102. The Secret to B2B Pricing in a Digital World | Bain & Company, accessed
November 12, 2025,
<https://www.bain.com/insights/the-secret-to-b2b-pricing-in-a-digital-world/>